COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.3 · Change Management

Mestre CyberSec · **Aula 1.3 — Change Management** (11:22) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Mudança em produção com segurança: documentar a requisição de mudança (RFC), checar risco, aprovar (CAB — Change Advisory Board), testar em ambiente isolado, agendar janela, ter plano de ROLLBACK, avisar afetados; executar, verificar, documentar. Emergency change: menos processo,

💡 Highlights que a prova CompTIA cobra

- Rollback plan: o que fazer se der errado — SEM isso, não aprova
- Emergency change: CAB rápido, ainda documentado
- Todo change passa por ambiente de TESTE antes de produção

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'requires rollback plan and testing before deployment' = change management
- 'emergency change bypasses some approvals' = ainda precisa de documentação

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.3 — Change Management)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Gerenciamento de Mudanças (CM)
Processo formal para solicitar, revisar, aprovar, testar e documentar qualquer modificação em sistemas de produção, minimizando interrupções e riscos de segurança.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase 'requires rollback plan and testing before deployment' = Change Management. Sempre cite o processo formal completo (RFC → análise de risco → teste → aprovação → execução).*

• Requisição de Mudança (RFC)
Documento formal de proposta enviado para iniciar qualquer mudança em produção, descrevendo o que mudará, o motivo, riscos associados e procedimentos de rollback.

⚠️ ***Armadilha CompTIA:*** *Toda mudança em produção COMEÇA com um RFC. Sem documentação formal, não existe mudança gerenciada válida.*

• Conselho Consultivo de Mudanças (CAB)
Grupo de partes interessadas que revisa e aprova/rejeita mudanças propostas, avaliando risco, impacto e recursos necessários antes de permitir a implantação.

⚠️ ***Armadilha CompTIA:*** *CAB approval = mandatory gate in change management. Em emergências, há um 'Emergency CAB' ou aprovação acelerada, mas NUNCA eliminada totalmente.*

• Plano de Reversão (N/A)
Procedimento documentado para reverter um sistema ao estado funcional anterior caso a mudança cause falha ou consequências indesejadas.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'no rollback plan' = change NÃO será aprovada. É a razão #1 de reprovação em perguntas de change management.*

• Mudança de Emergência (N/A)
Mudança necessária para restaurar serviço ou corrigir problema crítico de segurança que contorna o cronograma normal de aprovação do CAB, mas ainda exige documentação.

⚠️ ***Armadilha CompTIA:*** *'Emergency change bypasses some approvals' = ainda precisa de documentação pós-fato e aprovação retroativa. Nunca é totalmente sem processo.*

• Ambiente de Teste / Sandbox (N/A)

Ambiente isolado, fora de produção, onde mudanças são implantadas e validadas antes de serem promovidas para os sistemas de produção.

⚠️ ***Armadilha CompTIA:*** *Toda mudança DEVE passar por ambiente de teste antes de produção. Pular essa etapa é violação direta do change management.*

• Janela de Mudança (N/A)

Período pré-aprovado e agendado (geralmente em horários de baixo uso) durante o qual mudanças em sistemas de produção podem ser implantadas.

⚠️ ***Armadilha CompTIA:*** *Mudanças em produção fora da change window = violação. Janelas existem para minimizar impacto ao usuário e permitir resposta rápida a incidentes.*

• Análise de Impacto / Avaliação de Risco (N/A)

Avaliação de consequências potenciais, sistemas afetados e riscos de segurança associados a uma mudança proposta antes da aprovação.

⚠️ ***Armadilha CompTIA:*** *Sem análise de risco documentada, o CAB NÃO deve aprovar a mudança. É insumo obrigatório do RFC.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

O administrador de sistemas de uma empresa de serviços financeiros precisa aplicar um patch de segurança do fornecedor no servidor de autenticação de produção. O patch ainda não foi implantado em nenhum outro ambiente. De acordo com as boas práticas de gerenciamento de mudanças, qual ação o administrador deve tomar primeiro?

A) Enviar uma requisição de mudança e concluir uma análise de impacto e risco.

B) Aplicar o patch imediatamente porque está relacionado à segurança.

C) Notificar os clientes depois que o patch for instalado e verificado.

D) Criar um relatório pós-implementação para o Change Advisory Board revisar depois.

QUESTÃO 2 · CENÁRIO DE EXAME

O Change Advisory Board está revisando uma solicitação para abrir uma nova regra de firewall de entrada da internet para um aplicativo de pagamento. Qual informação é mais importante para o CAB decidir se aprova a mudança?

A) A quantidade de fornecedores de firewall usados pela organização.

B) A senioridade do engenheiro que enviou a solicitação.

C) O código orçamentário do departamento associado à mudança.

D) A justificativa de negócio documentada, a análise de risco e impacto, e o plano de rollback.

QUESTÃO 3 · CENÁRIO DE EXAME

Após a aprovação do CAB, uma equipe precisa validar novas alterações de configuração do servidor web antes que cheguem à produção. Qual ambiente deve ser usado para reduzir o risco de interrupção do serviço?

A) O ambiente de produção durante horário de baixo uso.

B) Um ambiente isolado de sandbox ou staging que replica a produção.

C) Um único nó de produção removido temporariamente do balanceador de carga.

D) O site de recuperação de desastres enquanto os usuários estão ativos.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de rede planeja atualizar o firmware de switches principais durante uma janela de manutenção. A atualização tem risco conhecido de causar instabilidade de roteamento. Qual controle prepara melhor a equipe para se recuperar rapidamente se a atualização falhar?

A) Uma política de uso aceitável assinada pela equipe de rede.

B) Uma janela de mudança mais longa sem notificação aos usuários.

C) Um plano de rollback documentado e backup atual das configurações dos switches.

D) Uma segunda requisição de mudança enviada após a atualização.

QUESTÃO 5 · CENÁRIO DE EXAME

Um administrador conclui uma mudança aprovada em um gateway de API de produção. O monitoramento mostra uso normal de CPU, mas a equipe de negócios relata que um endpoint crítico retorna erros. O que o administrador deve fazer em seguida como parte do gerenciamento de mudanças?

A) Fechar o chamado de mudança porque a janela programada terminou.

B) Verificar a mudança em relação aos critérios de sucesso e documentar o problema; se necessário, executar rollback.

C) Excluir imediatamente o registro da mudança para evitar achados de auditoria.

D) Esperar até a próxima reunião do CAB para investigar.

QUESTÃO 6 · CENÁRIO DE EXAME

Uma vulnerabilidade zero-day está sendo explorada ativamente contra a VPN pública da empresa. O fornecedor lança um patch emergencial fora do cronograma normal de manutenção. Qual é a abordagem de gerenciamento de mudanças mais apropriada?

A) Esperar a próxima reunião mensal do CAB para revisar o patch.

B) Implantar o patch sem aprovação ou documentação porque é urgente.

C) Usar o processo de mudança emergencial com aprovação acelerada e depois documentar e revisar.

D) Aplicar o patch em produção somente após um piloto completo de 30 dias em sandbox.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa agenda uma mudança para atualizar registros DNS do portal do cliente durante uma janela de manutenção de fim de semana. Qual ação melhor atende ao requisito de comunicação do processo de gerenciamento de mudanças?

A) Enviar notificação antecipada do cronograma, impacto esperado e contato de suporte aos usuários e equipes afetadas.

B) Publicar os detalhes da mudança apenas no chat privado da equipe de engenharia após a conclusão.

C) Evitar notificação para impedir que atacantes saibam da manutenção.

D) Avisar apenas o CAB, pois usuários finais não precisam saber sobre mudanças de DNS.

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de banco de dados propõe uma alteração de esquema em um banco de dados ERP de produção. O CAB exige um método documentado para restaurar o banco de dados ao estado anterior se a mudança causar corrupção de dados. Qual artefato o DBA deve fornecer?

A) Um acordo de nível de serviço (SLA).

B) Um plano de rollback.

C) Um memorando de entendimento (MOU).

D) Uma política de resposta a incidentes.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa precisa realizar uma grande atualização em sua plataforma de CRM de produção. A mudança foi aprovada para domingo, das 01:00 às 05:00, quando o uso é menor. Qual conceito de gerenciamento de mudanças esse cronograma representa principalmente?

A) Aprovação de mudança emergencial.

B) Separação de funções.

C) Janela de mudança.

D) Privilégio mínimo.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma mudança de produção em um balanceador de carga causou uma indisponibilidade. A equipe executou com sucesso o plano de rollback e restaurou o serviço. De acordo com as boas práticas de gerenciamento de mudanças, o que deve acontecer em seguida?

A) Reaplicar a mesma mudança imediatamente sem análise.

B) Fechar o chamado porque o rollback restaurou o serviço.

C) Realizar uma revisão pós-implementação e documentar lições aprendidas.

D) Transferir a requisição de mudança para a equipe de resposta a incidentes e não tomar mais nenhuma ação.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Enviar uma requisição de mudança e concluir uma análise de impacto e risco.
O primeiro passo é documentar formalmente a mudança e avaliar seu impacto e risco para que o CAB possa tomar uma decisão informada. Patches relacionados à segurança não ignoram automaticamente o controle de mudanças, a menos que se qualifiquem para o processo de mudança emergencial. Aplicar primeiro, notificar depois ou documentar apenas após a implementação pula aprovação, testes e análise de risco exigidos.

Questão 2: Alternativa D — A justificativa de negócio documentada, a análise de risco e impacto, e o plano de rollback.
As decisões do CAB devem se basear na necessidade de negócio, risco, impacto e na capacidade de recuperação se a mudança falhar. Quantidade de fornecedores, senioridade do engenheiro e códigos de orçamento não fornecem justificativa de segurança ou operacional suficiente para aprovar uma regra de firewall de alto risco.

Questão 3: Alternativa B — Um ambiente isolado de sandbox ou staging que replica a produção.
Um ambiente de sandbox ou staging isolado permite testar sem afetar usuários ou dados de produção. Testar em produção, mesmo em horário de baixo uso ou em um único nó, ainda introduz risco aos serviços ativos. O site de recuperação de desastres é para continuidade, não para validação rotineira de mudanças.

Questão 4: Alternativa C — Um plano de rollback documentado e backup atual das configurações dos switches.
Um plano de rollback com backups atuais de configuração fornece à equipe uma maneira testada de restaurar rapidamente o estado anterior se a atualização de firmware causar problemas. Uma janela maior ou uma solicitação posterior não restauram o serviço, e uma política de uso aceitável não está relacionada à recuperação técnica.

Questão 5: Alternativa B — Verificar a mudança em relação aos critérios de sucesso e documentar o problema; se necessário, executar rollback.
Após uma mudança, a equipe deve verificar se os critérios de sucesso foram atendidos e documentar o resultado. Se a verificação falhar, o plano de rollback deve ser seguido. Fechar o chamado, excluir registros ou esperar a próxima reunião do CAB ignora a mudança malsucedida e atrasa a recuperação.

Questão 6: Alternativa C — Usar o processo de mudança emergencial com aprovação acelerada e depois documentar e revisar.
Mudanças emergenciais permitem aprovação e implementação aceleradas para tratar riscos urgentes, mas ainda exigem documentação e revisão pós-implementação. Esperar o CAB mensal ou exigir um piloto de 30 dias deixa a organização exposta. Pular toda aprovação e documentação cria lacunas de responsabilidade e auditoria.

Questão 7: Alternativa A — Enviar notificação antecipada do cronograma, impacto esperado e contato de suporte aos usuários e equipes afetadas.
As partes interessadas afetadas devem receber aviso prévio sobre cronograma, impacto potencial e como obter suporte. Informar apenas engenheiros depois do ocorrido, ocultar a manutenção ou limitar a comunicação ao CAB não atende às necessidades de comunicação dos usuários e do negócio.

Questão 8: Alternativa B — Um plano de rollback.
Um plano de rollback documenta como reverter a mudança e restaurar o estado anterior se a implementação falhar. Um SLA define expectativas de serviço, um MOU registra um acordo entre partes, e uma política de resposta a incidentes orienta o tratamento de incidentes de segurança; nenhum fornece especificamente o procedimento de reversão para essa mudança.

Questão 9: Alternativa C — Janela de mudança.
Uma janela de mudança é um período agendado escolhido para reduzir o impacto no negócio e permitir tempo suficiente para implementação e recuperação. Aprovação de mudança emergencial é para mudanças urgentes não planejadas, separação de funções evita conflitos de papéis, e privilégio mínimo limita direitos de acesso.

Questão 10: Alternativa C — Realizar uma revisão pós-implementação e documentar lições aprendidas.
Após uma mudança malsucedida, uma revisão pós-implementação ajuda a identificar a causa raiz, atualizar procedimentos e documentar lições aprendidas para mudanças futuras. Simplesmente reaplicar, fechar o chamado ou transferir a solicitação sem acompanhamento perde a oportunidade de melhorar o gerenciamento de mudanças.